

# Conduct a Security Audit Exercise

## Controls assessment checklist

| Yes                                 | No                                  | Control                          | Explanation                                                                                                                                               |
|-------------------------------------|-------------------------------------|----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Least Privilege                  | Currently, all employees have access to internal data, including customer PII. Adding privileges and restricting access will reduce the risk of a breach. |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Disaster recovery plans          | There are no disaster recovery plans in place. Creating these plans will ensure business continuity.                                                      |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Password policies                | The password policy is not aligned with the current minimum password complexity requirements. Adding a system to enforce password policies is critical.   |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Separation of duties             | Access controls need to be implemented to reduce overall risk.                                                                                            |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Firewall                         | There is a firewall in place that blocks traffic based on an appropriate set of security rules.                                                           |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Intrusion detection system (IDS) | IDS has not been installed, the IT department needs to adjust this to help identify possible intrusions by threat actors.                                 |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Backups                          | The IT department needs to have backups of critical data to restore/ recover it in case of a breach.                                                      |

|                                     |                                     |                                                                     |                                                                                                                            |
|-------------------------------------|-------------------------------------|---------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Antivirus software                                                  | The password policy is not aligned with the current minimum password complexity requirements.                              |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Manual monitoring, maintenance, and intervention for legacy systems | Legacy systems are monitored, but not on a regular schedule and policies related to intervention are unclear.              |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Encryption                                                          | There is no encryption set up, implementing it would provide better confidentiality of sensitive information.              |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Password management system                                          | There is no password management system in place. As stated under password policies, implementing this system is necessary. |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Locks (offices, storefront, warehouse)                              | The store's physical location has sufficient locks.                                                                        |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Closed-circuit television (CCTV) surveillance                       | There is a CCTV surveillance system installed at the store's location.                                                     |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Fire detection/prevention (fire alarm, sprinkler system, etc.)      | The store has a functioning fire detection and prevention system.                                                          |

## Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

| Yes                      | No                                  | Best practice                                                            | Explanation                                                                                |
|--------------------------|-------------------------------------|--------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Only authorized users have access to customers' credit card information. | Employees currently have access to internal data, including customers' credit information. |

|                          |                                     |                                                                                                              |                                                                                    |
|--------------------------|-------------------------------------|--------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. | Credit information is accessible to employees and is not encrypted.                |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Implement data encryption procedures to better secure credit card transaction touchpoints and data.          | Internal data is not encrypted, posing a huge security risk.                       |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Adopt secure password management policies.                                                                   | Password policies are minimal and there is no password management system in place. |

#### General Data Protection Regulation (GDPR)

| Yes                                 | No                                  | Best practice                                                                                                     | Explanation                                                                                     |
|-------------------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | E.U. customers' data is kept private/secured.                                                                     | Customers' financial information is not secured due to the lack of encryption.                  |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. | The company currently follows this policy.                                                      |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Ensure data is properly classified and inventoried.                                                               | Assets have been listed, but have not been classified for appropriate management.               |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Enforce privacy policies, procedures, and processes to properly document and maintain data.                       | Some privacy policies, procedures, and processes have been created and enforced by the IT team. |

## System and Organizations Controls (SOC type 1, SOC type 2)

| Yes                                 | No                                  | Best practice                                                                              | Explanation                                                                                                              |
|-------------------------------------|-------------------------------------|--------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | User access policies are established.                                                      | All employees have access to internal data, controls of least privilege and separation of duties need to be implemented. |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Sensitive data (PII/SPII) is confidential/private.                                         | There are not enough policies in place to keep PII confidential, including a lack of encryption.                         |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Data integrity ensures the data is consistent, complete, accurate, and has been validated. | The IT department has ensured availability and integrated controls to ensure data integrity.                             |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Data is available to individuals authorized to access it.                                  | Data is currently available to all employees, limited authorization needs to be implemented to secure customer PII.      |

**Recommendations (optional):** In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

After reviewing the risk assessment report and conducting a security audit, it is imperative that Botium Toy's security controls and policies be updated. There are several controls that need to be implemented to improve the company's security posture and better ensure the confidentiality of sensitive information. Improvements to the following controls are necessary: least privilege, disaster recovery plans, updated password policies, separation of duties, an IDS, legacy management systems, encryption, and a password management system.

To better align the company with compliance standards, more controls need to be enforced. These controls include least privilege, separation of duties, and encryption. There also needs to be a system to properly classify assets in order to identify additional controls that may need to be implemented to improve security posture and better protect sensitive information.